



Mevcut yapıyı bozmadan güçlendirme planı

DOSSO DOSSI COFFEE

Entegrasyon ve local çalışma tercihleri dışında.
Odak: mevcut işleyiş, veri tutarlılığı ve kullanıcı deneyimi.

BU RAPORUN YENİ ÇERÇEVESİ

Ödeme, Kerzz POS, SMS ve local altyapı bilinçli tercihler olarak kabul edildi.

Dış bilgi beklemeden yapılabilecek 21 düzeltme paketi ile 3 bakım/hazırlık işi. Her biri için somut örnek, küçük çözüm ve doğrulama ölçütü.

Sürüm: berkay-branch / d3cfc34

Yöntem: Önceki kanıtların yeni kapsamla değerlendirilmesi.

Uygulamaya etkisi: Kaynak, ayar ve mevcut veri değiştirilmedi.

Yeni bilgiyle değerlendirmem

Sağlayıcıdan bilgi beklemek ve backend/veritabanını local çalıştırmak, bu raporda hata veya olgunluk eksiği olarak sayılmıyor.

Ana mimari korunabilir

Flutter repository yapısı, backend servisleri, PostgreSQL kayıtları ve admin modülleri üzerine devam edilebilir. Önceki rapordaki dış entegrasyon eksiklerinden yola çıkarak bir yeniden yazım önermiyorum.

21 düzeltme

Mevcut kodun davranışını iyileştiren bağımsız iş paketleri.

3 bakım işi

Derleme, paket bakımı ve ölçüme dayalı performans.

0 kaynak değişimi

Bu çalışma değerlendirme ve PDF üretimi; düzeltmeler henüz uygulanmadı.

EN YÜKSEK GETİRİLİ SIRA

Önce	Neden?
Para ve ikram tutarlılığı	Çift iade, negatif bakiye/hak ve kaybolan damga testte görüldü. Bunlar mevcut iç servis mantığı.
Hesap ve şube sınırları	Kullanıcı/admin değişiminde eski veri kalabiliyor; bazı şube rolü okumaları global.
Fiyat ve ayar sözleşmesi	Paneldeki fiyat/kural ile müşterinin gördüğü değer aynı kaynaktan gelmeli.
Bekleyen iş ve hata görünürlüğü	Aktif sipariş panosu, auth retry, QR süresi ve boş/hata durumları güvenilir olmalı.
Panel ve görsel tutarlılık	Eksiksiz rapor, doğru kurş/KPI ve grid-detay görsel eşleşmesi müdür işini kolaylaştırır.

Sonuç: çekirdek yapı üzerinde ilerlemek mantıklı. Dış bağlantılar gelene kadar en verimli yatırım, küçük servis düzeltmeleri ve bunları koruyan regresyon testleridir.

Neleri hata listesinden çıkardım?

Kullanıcının açıklaması esas alınarak, bilinçli bekletilen işler ile mevcut kod hataları ayrıldı.

Konu	Yeni değerlendirme
Ödeme sağlayıcısı / 3DS / kart ekleme	Bilerek ertelenmiş. Gerçek sağlayıcının olmaması ve geliştirme simülasyonu mevcut hata listesinde yok.
Kerzz POS bağlantısı	Karşı tarafın sözleşme/bilgisi bekleniyor. Kasaya gönderim ve gerçek POS onayı eksik diye puan düşürülmüyor.
SMS / hediye teslim bildirimi / bağlı push	Dış bağlantıya bağlı geliştirme kapsamı. Gönderilmemesi bu raporda hata sayılmıyor.
Local backend + local veritabanı	Bilinçli geliştirme ortamı. Localhost, yerel HTTP, geliştirme DB'si ve sunucuya taşınmamış olması sorun olarak yazılmıyor.
Canlı hosting / TLS / prod dağıtım / imza	Canlıya geçiş aşamasında ayrıca planlanacak işler. Mevcut local uygulamanın bozuk olduğuna kanıt değil.
Gerçek sağlayıcıyla uçtan uca deneme	Bilgiler geldiğinde yapılacak. Şimdiki bağımsız düzeltme paketlerine koşul olarak eklenmiyor.

Hangi sorunlar yine listede kaldı?

Aynı local servis iki kez iade yazıyorsa, admin çıkışından sonra eski veri görünüyorsa veya kullanıcı yanlış şubeye yönleniyoysa bunu dış firma bilgisi çözmez. Bu nedenle iç iş kuralı, oturum ve UI tutarlılığı sorunları listede kaldı.

Birleştirilmiş konu ayrımı: "push bağlanmamış" dışarıda, "tercih kaydı son seçimi eziyor" içeride. "Kerzz hazır değil" dışarıda, "mevcut QR ekranı eski kodun süresini sıfırlıyor" içeride. "Banka yok" dışarıda, "aynı cüzdan siparişi iki kez oluşuyor" içeride.

Kanıtı nasıl okumalı?

Bu belge yeni bir tam tarama değildir. Aynı kod sürümünün önceki denetim kanıtları, güncellenen kapsamla yeniden yorumlandı.

Bilgi	Durum
Kaynak sürümü	d3cfc34cd869b83093bb60de21a83e07aae5cc55. Bu turda commit ve çalışma ağacı tekrar kontrol edildi; uygulama kodu aynı.
Önceki mobil doğrulama	29/29 test geçti; flutter analyze temiz. Auth kuyruğu, sepet, timer ve küçük ekran için ayrı problemler var.
Önceki backend doğrulama	143/143 mevcut regresyon testi geçti. Ayrı PostgreSQL'de 14 ek senaryo kusurlu sonuçları doğruladı.
Önceki admin doğrulama	Typecheck/build/lint geçti. Gerçek fonksiyonlarla sentetik bellek verisi üzerinden cache/filtre/export/validator kontrolleri yapıldı.
Bu tur yapılan	Bulgular tekrar sınıflandırıldı ve ortak işler birleştirildi. Testler tekrarlanmadı; mevcut DB'de işlem yapılmadı.

ETİKETLERİN ANLAMI

Etiket	Nasıl yorumlanmalı?
İzole DB / Flutter / bellek	Kontrollü testte davranış tekrar üretildi. Gerçek müşteri veya sağlayıcı kullanılmadı.
Statik kanıt	Kod akışı uyumsuzluğu gösteriyor; cihazda/üretimde gerçekleşme sıklığı ölçülmedi.
Statik risk / ölçülmedi	Önleyici kontrol veya ölçüm ihtiyacı. Doğrulanmış saldırı/yavaşlık diye sunulmuyor.
D01...D24	Tekrarlanan eski bulgular aynı iş paketinde toplandı. 24 paket, 24 ayrı güvenlik açığı anlamına gelmez.

Kabul testleri, gelecekte düzeltmenin tamamlandığını gösterecek ölçütlerdir. Denetim problemlerinin geçmesi, hatanın doğrulandığını gösterir; güvenli davranış onayı değildir.

Dış firmadan bağımsız dört örnek

Aşağıdaki veriler ayrı denetim ortamındaki sentetik örneklerdir. Gerçek bakiye veya müşteriye ait değildir.

İşlem	Doğru sonuç	Gözlenen sonuç	Paket
Çift iptal	1.000 TL	1.190 TL	D01
Tek ikram / iki sipariş	En çok 1 ücretsiz	2 ücretsiz, hak -1	D03
Manuel bakiye düzeltme	20 TL / biri reddedilir	-60 TL / ikisi kabul	D02
Cüzdan CSV	275 satır	200 satır	D18

Bu örnekler neden hâlâ önemli?

Hiçbirinde canlı banka veya gerçek POS cihazı gerekmiyor. Sorun, kendi servislerimizin aynı kaydı nasıl kontrol ettiği, güncellediği ve gösterdiğiyle ilgili. Sağlayıcı bilgisi gelmeden düzeltmek, sonradan entegrasyon testini kolaylaştırır.

KÜÇÜK DÜZELTME DÖNGÜSÜ

1

Sorunu testte göster

2

Tek servis/ekranı düzelt

3

Eski testleri koru

4

Aynı örneği yeniden doğrula

Görsel tema, navigasyon, repository/servis ayrımı ve mevcut çalışan normal akışlar korunur. Gereken veri değişiklikleri yalnız ilgili alana, geriye uyumlu ve kontrollü şekilde eklenir.

Para ve ikram tutarlılığı

Önceki kayıt kimlikleri ve incelenen commit'e bağlı kod satırları her paketin altında. B/ backend, M/ mobil, A/ admin.

D01 | ÖNCE DÜZELT | İZOLE DB KANITI

Aynı siparişe yalnız bir kez iade

Panelden aynı siparişe iki iptal aynı anda gelince iki iade oluşuyor. Testte 1.000 TL başlangıç, 190 TL sipariş sonrası 810 TL; iki iptal sonrası 1.190 TL görüldü.

İşletmeye etkisi: Bu, banka veya Kerzz eksikliği değil; mevcut panel iptal servisindeki eşzamanlı işlem hatasıdır.

Yapıyı koruyan çözüm: İptali yalnız uygun eski durumdan atomik olarak sahiplenilen güncelleme kullan. İkinci istek önceki sonucu dönsün; tek iade için benzersiz kayıt ekle. İptal ekranı ve normal akış aynı kalabilir.

Kabul kontrolü: 10 paralel iptalde bakiye tam 1.000 TL, tek iade ve doğru ikram/damga ters kaydı.

Kanıt: Önceki kayıtlar: BE-06

B/features/admin/orders.service.ts:186 · dosso-dossi-backend/prisma/schema/prisma:215

D02 | ÖNCE DÜZELT | İZOLE DB KANITI

Bakiye düzeltmesi ve kuruş hassasiyeti

100 TL hesaba paralel iki -80 TL düzeltme, -60 TL bakiye üretiyor. Ayrı hediye testinde 0,005 TL girdi, gönderenden 0 TL düşüp 0,01 TL hediye kaydı oluşturdu.

İşletmeye etkisi: Cüzdan ile hareket defteri farklı gerçeği gösterir. Her iki sorun mevcut iç işlemlerde; sağlayıcı bilgisi gerektirmez.

Yapıyı koruyan çözüm: Eksi düzeltmeyi bakiye yeterliyse atomik düş. Para girişini en fazla iki ondalıkla sınırla veya tek normalize kuruş değeri kullan; tüm kayıtlara aynı tutarı yaz.

Kabul kontrolü: İki -80 düzeltmenin yalnız biri kabul, bakiye 20 TL. Her harekette bakiye farkı = defter tutarı. Kuruş altı girdiler açık kuralla reddedilir/normalize edilir.

Kanıt: Önceki kayıtlar: BE-10, BE-11

B/features/admin/customers.service.ts:195 · B/features/gifts/gifts.schemas.ts:8 · B/features/gifts/gifts.service.ts:33

Para ve ikram tutarlılığı / devam

D03 | ÖNCE DÜZELT | İZOLE DB KANITI

İkram ve damga hesabını yarışlara kapat

Tek ikram iki paralel siparişte tüketildi ve hak -1 oldu. İki sadakat olayı iki kayıt üretip yalnız bir damga artırdı. İki farklı ilk yükleme onayı, 5 yerine 10 bonus verdi.

İşletmeye etkisi: İkram tüketimi/kazanımı, mevcut sadakat servisinin sorumluluğu. Gerçek ödeme bağlantısı beklenirken bu hesaplamalar bağımsız düzeltilebilir.

Yapıyı koruyan çözüm: Sadakat hesabı için ortak kilit/sürüm kontrolü; hak tüketiminde koşullu atomik azaltma; kullanıcı+kampanya için tek seferlik bonus sahiplenmesi ekle. Ödül oranlarını değiştirme.

Kabul kontrolü: Bir hak en fazla bir kez kullanılır; 10 ayrı kazanım kaybolmaz; farklı ilk yüklemeler yalnız bir kampanya bonusu verir.

Kanıt: Önceki kayıtlar: BE-07, BE-08, BE-09

B/features/orders/orders.service.ts:75 · B/features/wallet/payments/topup.service.ts:100 · B/features/loyalty/loyalty-apply.ts:22 · B/features/orders/orders.service.ts:94

D04 | ÖNCE DÜZELT | İZOLE DB + STATİK KANIT

Tek kullanıcı niyeti, tek işlem

Aynı sipariş gövdesinin iki gönderimi iki sipariş ve iki cüzdan düşümü oluşturdu. Mobilde işlem anahtarı yok; yükleme onayı sırasında ikinci isteği engelleyen ortak kilit de bulunmuyor.

İşletmeye etkisi: Yanıt kaybolup kullanıcı yeniden bastığında ikinci işlem oluşabilir. Bu, ödeme firmasının seçilmesinden bağımsız API sözleşmesidir.

Yapıyı koruyan çözüm: Her niyet için kalıcı işlem UUID'si üret. Backend aynı kullanıcı+anahtar için önceki sonucu dönsün; farklı içerikle aynı anahtarı reddetsin. Mobil belirsiz sonucu sorgulasın, aynı anahtarla denesin.

Kabul kontrolü: Ağ yanıtı düşürülüp 10 tekrar gönderildiğinde tek kayıt. Kullanıcı bilinçli yeni sipariş verdiğinde yeni anahtarla normal işlem.

Kanıt: Önceki kayıtlar: BE-12, MOB-04

B/features/orders/orders.schemas.ts:3 · M/features/order/data/api_order_repository.dart:22 · B/features/orders/orders.routes.ts:11 · M/features/gift/data/api_gift_repository.dart:22

Hesap, yetki ve ağ davranışı

Önceki kayıt kimlikleri ve incelenen commit'e bağlı kod satırları her paketin altında. B/ backend, M/ mobil, A/ admin.

D05 | ÖNCE DÜZELT | ROUTE / BELLEK + STATİK

Şube müdürünün veri sınırını tamamla

Sipariş uçlarında şube sınırı varken CRM, cüzdan defteri ve bazı finans okumaları global. Sentetik şube müdürüyle gerçek müşteri route'u kabul edildi; servis sorgusunun şube filtresi boş kaldı.

İşletmeye etkisi: Bir şube rolü diğer müşterilerin telefon, bakiye ve finans bilgilerini görebilir. Menü gizlemek bu sunucu sınırını düzeltmez.

Yapiyı koruyan çözüm: Rol matrisi belirle; şubeyle ilişkilendirilemeyen global cüzdan/CRM verisini şube rolüne kapat veya dar bir DTO sun. Aynı sınırı CSV/XLSX uçlarına uygula.

Kabul kontrolü: B1 rolü B2/global finans verisini doğrudan HTTP ve dosya indirmede okuyamaz; yetkili merkez rolleri çalışmaya devam eder.

Kanıt: Önceki kayıtlar: ADM-02

B/middleware/admin-auth.ts:84 · B/features/admin/modules.routes.ts:345

D06 | ÖNCE DÜZELT | İZOLE BELLEK / FLUTTER

Hesap değişiminde veri ve sepeti ayır

Admin çıkış/girişinde ortak sorgu ön belleği temizlenmiyor. Probda yeni hesabın sorgusu çalışmadan eski global veri döndü. Mobil çıkışında sepet ve ikram seçimi de kaldı.

İşletmeye etkisi: Yeni hesap, önceki hesabın verisini veya alışveriş niyetini devralabilir. Banka/POS ile ilişkili bir eksik değildir.

Yapiyı koruyan çözüm: Oturum değişiminde bekleyen sorguları iptal et, admin cache'i temizle ve anahtara oturum kapsamı ekle. Mobil sepet/ikram/şube durumunu açık politikayla sıfırla; geç yanıtları oturum kimliğiyle kontrol et.

Kabul kontrolü: A hesabından B'ye geçişte ilk kareden itibaren A verisi görünmez; eski yanıt B'nin sepetini değiştiremez.

Kanıt: Önceki kayıtlar: ADM-01, MOB-07

A/App.tsx:17 · M/features/auth/application/auth_controller.dart:92 · A/auth/AuthContext.tsx:54 ·

M/features/order/application/cart_controller.dart:16

Hesap, yetki ve ağ davranışı / devam

D07 | ÖNCE DÜZELT | İZOLE DB / BELLEK KANITI

Bloklama ve oturum kapatma gerçekten etkili olsun

Bloke müşteri mevcut token ile sipariş verebildi: 201 yanıtı ve 1.000 -> 810 TL. Admin şifre/oturum iptali yalnız refresh token'ı kaldırıyor; mevcut access token kalan ömründe kabul ediliyor.

İşletmeye etkisi: Hesabı durdurma ile erişim biletini yenilememe farklı şeyler. Şüpheli işlem sırasında beklenen anlık kesme sağlanmıyor.

Yapıyı koruyan çözüm: Finansal işlemlere merkezi aktif-hesap kontrolü koy. Anlık oturum iptali gereken eylemlerde tokenVersion/tokensValidAfter kontrolü kullan. Normal çıkış politikasını açık tanımla.

Kabul kontrolü: Bloke hesap yeni sipariş/hediye/QR işlemi yapamaz. Tüm oturumları iptal sonrası eski access token reddedilir; yeni giriş çalışır.

Kanıt: Önceki kayıtlar: BE-04, ADM-03, BE-22

B/middleware/auth.ts:18 · B/features/admin/admin-auth.service.ts:135 · B/features/admin/admin-auth.service.ts:142 · B/features/admin/customers.service.ts:292

D08 | ÖNCE DÜZELT | İZOLE FLUTTER + STATİK

Oturum yenileme hatasında ekran takılmasının

Aynı Dio hata kuyruğu içinden tekrar istek bekleniyor. Çevrimdışı probda retry 200 tamamlandı; retry 401/503 askıda kaldı. Refresh ağ hatası da geçerli token'ları silebiliyor.

İşletmeye etkisi: Sepet veya veri yükleme sonsuz bekleyebilir; kısa bağlantı kesintisi gereksiz yeniden girişe dönüştürülebilir.

Yapıyı koruyan çözüm: Token yenilemeyi tek ortak Future ile yönet; retry'ı aktif hata kuyruğuna tekrar sokma. Açık timeout uygula, ağ hatasıyla gerçekten geçersiz oturumu ayır.

Kabul kontrolü: 401 ardından 200/401/503/timeout sonuçlarının hepsi tamamlanır. Paralel istekler tek refresh kullanır; geçici offline oturumu silmez.

Kanıt: Önceki kayıtlar: MOB-01, MOB-19

M/core/network/api_client.dart:33 · M/core/network/api_client.dart:105 · M/core/network/api_client.dart:88 · M/core/network/api_client.dart:116

Fiyat, kampanya ve şube kuralları

Önceki kayıt kimlikleri ve incelenen commit'e bağlı kod satırları her paketin altında. B/ backend, M/ mobil, A/ admin.

D09 | ÖNCE DÜZELT | STATİK + İZOLE DB KANITI

Müşterinin onayladığı fiyatı koru

Mobil süt/shot farkları sabit, şube fiyatı global katalogdan geliyor; backend güncel şube ve opsiyon fiyatını kullanıyor. Fark yalnız tahsilattan sonra bildiriliyor. Pasif opsiyon da 0 farkla kabul edildi.

İşletmeye etkisi: Bu bir banka tahsilat testi değil; mevcut cüzdan siparişinde fiyat sözleşmesi ve seçenek doğrulama sorunu.

Yapıyı koruyan çözüm: Seçili şube ve aktif seçenekleri API'den oku. Checkout öncesi fiyat teklifi veya expectedTotal/quoteVersion doğrula; fark varsa para düşmeden onaylat. Geçersiz opsiyonu reddet.

Kabul kontrolü: 190 -> 210 TL değişimi önceden görünür/onaylanır. Pasif/yabancı opsiyon 400 döner; aktif seçenek tanımlı tutarı ekler.

Kanıt: Önceki kayıtlar: MOB-02, BE-16

M/features/order/domain/product_options.dart:15 · B/features/orders/orders.service.ts:15 ·

M/features/order/data/api_menu_repository.dart:49 · B/features/orders/orders.service.ts:50

D10 | ÖNCE DÜZELT | VALIDATOR PROBU + STATİK

Panel ayarı, afiş ve gerçek kural aynı olsun

Ayar API'si 1,5 ikram, negatif eşik ve metin "false" kabul etti. Damga hedefi ayarı kaydoluyor ama hesap hedefini değiştirmiyor. Kampanya afişi/SSS bazı değerleri sabit kullanıyor.

İşletmeye etkisi: Panel "kaydedildi" derken uygulama başka kuralla çalışabilir. Entegrasyon tamamlanması bu iç veri sözleşmesini kendiliğinden düzeltmez.

Yapıyı koruyan çözüm: Anahtara göre tip/aralık kontrolü yap. Mevcut kart haklarını koruyan hedef geçiş politikası belirle. Afiş, SSS, detay ve hesaplamayı yapılandırılmış ortak kampanya modelinden besle.

Kabul kontrolü: Geçersiz ayarlar reddedilir. Testte seçilen yeni eşik/ödül tüm ekranlarda aynı görünür; birikmiş damgalar kaybolmaz.

Kanıt: Önceki kayıtlar: ADM-05, ADM-06, MOB-12

B/features/admin/modules.routes.ts:284 · B/features/settings/settings.service.ts:10 · M/core/constants/app_config.dart:34 ·

B/features/settings/settings.service.ts:46

Fiyat, kampanya ve şube kuralları / devam

D11 | PLANLI İYİLEŞTİR | STATİK KANIT

Şube seçimi ve özel fiyatı koru

Liste ekranında B şubesinin “Sipariş Ver” eylemi, aktif A şubesini değiştirmiyor. Panel ürün aç/kapa isteği priceOverride:null gönderip mevcut özel fiyatı siliyor.

İşletmeye etkisi: Yanlış şubeye sipariş niyeti ve fark edilmeden fiyat değişimi oluşabilir.

Yapıyı koruyan çözüm: Tüm şube giriş noktaları aynı seç-ve-yönlendir aksiyonunu kullansın. Müsaitlik güncellemesinde gönderilmeyen fiyat korunsun; null yalnız açık fiyat temizleme işlemi olsun.

Kabul kontrolü: A seçiliyken B kartından sipariş B ile açılır. 210 TL özel fiyatlı ürünü kapat/aç sonrasında fiyat 210 TL kalır.

Kanıt: Önceki kayıtlar: MOB-09, ADM-10

M/features/branches/presentation/branch_list_screen.dart:47 · A/features/branches/BranchesPage.tsx:287 ·

M/features/branches/presentation/branch_list_screen.dart:179 · B/features/admin/menu.service.ts:298

D12 | PLANLI İYİLEŞTİR | İZOLE DB KANITI

Kahve hediyesinin ürün kuralını netleştir

İçecek hediyesi isteğine aktif ama içecek olmayan ürün verilebiliyor; alıcıya genel ikram hakkı ekleniyor. Testte 1 TL'lik sentetik mug ürünü bir ikram hakkına dönüştü.

İşletmeye etkisi: Sorun SMS'in gönderilmemesi değil; seçilen ürünün fiyatı ile verilen hakkın uyuşmaması. Gerçek menüde 1 TL ürün var iddiası değildir.

Yapıyı koruyan çözüm: Sunucuda hediye edilebilir ürün kuralı uygula. “Seçilen ürün hediyesi” mi “genel kahve hakkı” mı kararını metin, fiyat ve kullanımda eşitle. Kendine hediye kuralını ayrıca kararlaştır.

Kabul kontrolü: Mug/paket çekirdek gibi uygun olmayan ürünler reddedilir. Gönderilen ürün/hak, alıcının kullanabildiği hakla aynı sözleşmeye uyar.

Kanıt: Önceki kayıtlar: BE-13

B/features/gifts/gifts.service.ts:18 · B/features/gifts/gift-claim.ts:50

Sipariş ve mobil kullanım

Önceki kayıt kimlikleri ve incelenen commit'e bağlı kod satırları her paketin altında. B/ backend, M/ mobil, A/ admin.

D13 | ÖNCE DÜZELT | STATİK KANIT

Aktif sipariş panosunda iş kaybolmasın

Pano tüm durumlar arasından yalnız en yeni 25 siparişi alıp aktif sütunları tarayıcıda oluşturuyor. Eski bekleyen iş, yeni tamamlanan kayıtların arkasında kaybolabilir; liste filtresi panoya da taşıyor.

İşletmeye etkisi: Bu, Kerzz bağlantısı değil; mevcut admin listesinin sorgu ve görünüm davranışı.

Yapıyı koruyan çözüm: Pano sorgusunu sunucuda aktif durumlara ayır. Tüm aktif kayıtları sayfala veya imleçle devam ettir; liste arama/durum filtresini panodan bağımsız tut.

Kabul kontrolü: 30 yeni tamamlanmış kayıttan eski RECEIVED sipariş görünür. Listeye COMPLETED filtresi verip panoya geçmek aktif işleri gizlemez.

Kanıt: Önceki kayıtlar: ADM-04
A/features/orders/OrdersPage.tsx:114 · A/features/orders/OrdersPage.tsx:211

D14 | PLANLI İYİLEŞTİR | STATİK KANIT

QR ekranı kendi süresine güvenilir davranır

Yenileme hatasında eski QR tutulup sayaç yeniden 60 oluyor. Sunucudan gelen expiresAt ekranda kullanılmıyor; ilk hatada sürekli spinner görülebiliyor.

İşletmeye etkisi: Kasaya bağlanıp bağlanmadığı bu değerlendirmede yok. Mevcut ekranın süresi geçmiş kodu yeniymiş gibi sunması bağımsız UI hatasıdır.

Yapıyı koruyan çözüm: Duvar saati ve expiresAt kullan. Süre bitince eski kodu gizle; hata/yeniden dene göster. Tek açık yenileme isteği tut; görünmeyen/arka plandaki ekranın timer'ını durdur.

Kabul kontrolü: Offline durumda sayaç sıfırlanmaz; 90 saniye arka plan sonrası eski kod kullanılabilir görünmez; gecikmeli istekte tek yenileme kalır.

Kanıt: Önceki kayıtlar: MOB-05
M/features/scan_pay/presentation/scan_pay_screen.dart:45 · M/features/scan_pay/presentation/scan_pay_screen.dart:75

Sipariş ve mobil kullanım / devam

D15 | PLANLI İYİLEŞTİR | STATİK KANIT

Yenileme, boş veri ve tercih hatalarını görünür yap

Home yenilemesi cüzdan/sadakati yenilemiyor; geçmiş hatası boş listeye dönüşebiliyor. Boş şube first erişimini bozuyor. Bildirim tercihinde geç yanıt son seçimi ezebilir.

İşletmeye etkisi: Kullanıcı “veri yok” ile “yüklenemedi” durumlarını ayıramaz. Burada push teslimi değil, mevcut tercih kaydının tutarlılığı değerlendiriliyor.

Yapıyı koruyan çözüm: Loading/error/empty durumlarını ayır. Pull-to-refresh ilgili hesap verilerini beklesin. Geçerli şube olmadan ödeme eylemini kapat ve nedenini göster. Tercih yazılarını sırala/sürümle.

Kabul kontrolü: Ağ hatasında tekrar dene çalışır; boş şube sessiz başarısızlık üretmez; ters sırada GET/PUT yanıtlarında son tercih korunur.

Kanıt: Önceki kayıtlar: MOB-10, MOB-15, MOB-11

M/features/home/presentation/home_screen.dart:34 · M/features/order/application/order_providers.dart:27 ·

M/features/profile/application/notification_prefs.dart:10 · M/core/sync/app_data_sync.dart:36

D16 | PLANLI İYİLEŞTİR | WIDGET PROBU + STATİK

Küçük ekran ve erişilebilirliği tamamla

İzole widget probunda 375×667 görünüm, 44 px üst güvenli alan ve 336 px alt viewInsets ile mağaza gövdesi 59 px taştı. Bazı ikonlarda erişilebilir eylem adı/rolü ve dinamik ilerleme açıklaması eksik.

İşletmeye etkisi: Arama sonuçlarına veya butonlara erişim zorlaşabilir. Ekran okuyucu davranışı gerçek cihazda henüz denenmedi.

Yapıyı koruyan çözüm: Başlık/arama/afiş/kategori/grid'i ortak kaydırmaya al veya klavyede afişi daralt. Mevcut görsel dili koruyarak semantics, geniş dokunma alanı ve büyük yazı sarımı ekle.

Kabul kontrolü: 320×568 ve 375×667'de klavye açık, büyük yazıda taşma yok. VoiceOver/TalkBack sepet, favori ve ilerlemeyi anlamlı okur.

Kanıt: Önceki kayıtlar: MOB-13, MOB-14

M/features/shop/presentation/shop_screen.dart:69 · M/features/shop/presentation/shop_screen.dart:259 ·

M/features/shop/presentation/shop_screen.dart:141 · M/features/order/presentation/product_detail_screen.dart:205

Panel, görsel ve doğrulama

Önceki kayıt kimlikleri ve incelenen commit'e bağlı kod satırları her paketin altında. B/ backend, M/ mobil, A/ admin.

D17 | PLANLI İYİLEŞTİR | STATİK KANIT

Yeni ürün fotoğrafı her yerde aynı görünsün

Panel tek imageUrl alanını değiştiriyor; mevcut gridImageUrl eski kalabiliyor. Mobil grid eski türevi, ürün detayı yeni görseli seçiyor.

İşletmeye etkisi: "Panel değişikliği yansımıyor" izlenimi oluşur; gerçek sorun iki farklı görsel alanının yönetilmemesi olabilir.

Yapiyı koruyan çözüm: Grid ve detay görsellerini panelde ayrı yönet veya tek görsel değişiminde grid türevini açık kuralla yenile. Yeni görsele sürümlü URL ver.

Kabul kontrolü: Panelde değişen ürün, sipariş grid'i, hediye seçimi ve detayda doğru yeni görseli gösterir. Mevcut kırpma/ölçüler korunur.

Kanıt: Önceki kayıtlar: ADM-12
B/features/admin/menu.service.ts:116 · A/features/menu/MenuPage.tsx:363

D18 | PLANLI İYİLEŞTİR | BELLEK PROBU + STATİK

Finans dışı aktarımı eksiksiz ve güvenli olsun

275 hareketin CSV'si 200 satır çıktı; XLSX arama filtresini yok saydı. =1+1 metni CSV'de formül başlangıcı olarak kaldı. Panel para biçimi kurulumları yuvarlıyor.

İşletmeye etkisi: Muhasebe ve ekrandaki toplam farklı görünebilir. CSV formül etkisi açan yazılım/ayarına bağlıdır; Excel'de çalıştırma testi yapılmadı.

Yapiyı koruyan çözüm: Liste/CSV/XLSX ortak filtre kullansın. Export tüm sayfaları alsın veya sınırı açık söylesin. Dış metni formüle karşı sabitle; finans tutarını iki ondalık göster.

Kabul kontrolü: 275 kayıt -> 275 satır; aynı filtre aynı ID'ler; zararlı başlangıçlar metin; 425,50 TL ekran ve dosyada aynı.

Kanıt: Önceki kayıtlar: ADM-07, ADM-08, ADM-09, ADM-14
B/features/admin/orders.service.ts:346 · B/features/admin/finance.service.ts:184 · A/features/orders/OrdersPage.tsx:174 · A/components/ui.tsx:132

Panel, görsel ve doğrulama / devam

D19 | PLANLI İYİLEŞTİR | İZOLE DB + STATİK

Müdür raporlarını gerçek kayıtlarla eşleştir

Sipariş iadesi defterde olsa da detayın hareket listesinde yok. CRM harcama sıralaması yalnız sayfa içinde; 5 ikram bonusu KPI'da 1 olay sayılabiliyor. Müşteri360 DTO'sunda sipariş sayısı eksik.

İşletmeye etkisi: Para her zaman yanlış değildir; yöneticiye sunulan iz ve ölçüm yanıltıcı olabilir.

Yapıyı koruyan çözüm: Ödeme ve iadeyi aynı siparişe çoklu hareket bağıyla bağla; tek iade güvencesini koru. LTV'yi sayfalama öncesi sırala. KPI'da olay yerine hak adedini, DTO'da gerçek toplamı kullan.

Kabul kontrolü: İptal detayında ödeme+iade görünür; en eski yüksek harcamalı müşteri sıralamada öne gelir; 5 bonus KPI'da 5 olur.

Kanıt: Önceki kayıtlar: BE-17, ADM-13, ADM-N01, ADM-N02

B/features/admin/orders.service.ts:95 · B/features/admin/customers.service.ts:25 · A/features/customers/CustomersPage.tsx:32 · B/features/admin/dashboard.service.ts:66

D20 | PLANLI İYİLEŞTİR | İZOLE DB + STATİK RİSK

OTP tüketimi ve deneme sınırlarını güçlendir

Aynı geçerli test OTP'si iki eşzamanlı tüketimde kabul edildi. Limiter yeni anahtarlarda temizlik dalını atlayabiliyor; farklı telefonlara gönderimde IP kotası eksik.

İşletmeye etkisi: Bu SMS sağlayıcısı seçimi değildir; mevcut doğrulama ve kaynak koruma mantığıdır. OTP'siz hesap ele geçirme kanıtı yoktur.

Yapıyı koruyan çözüm: OTP'yi kullanılmamış/geçerli/limit-altı koşuluyla atomik tüket. Deneme sayacı ve kota atomik olsun. TTL temizliğini tüm dallardan bağımsızlaştır; çoklu sunucuda ortak limit deposu planla.

Kabul kontrolü: Aynı kodla 10 paralel doğrulama yalnız bir başarı verir. Sanal saat testinde eski anahtarlar temizlenir; farklı telefonlar IP limitini aşamaz.

Kanıt: Önceki kayıtlar: BE-15, BE-20

B/features/auth/otp.service.ts:39 · B/middleware/rate-limit.ts:19 · B/features/auth/otp.service.ts:18 · B/features/auth/auth.routes.ts:26

Panel, görsel ve doğrulama / devam

D21 | PLANLI İYİLEŞTİR | FLUTTER PROBU + STATİK

Takip ekranının yaşam döngüsünü düzelt

İlk isteğin yanıtı gelmeden ekran kapatılıp yanıt sonra geldiğinde yeni timer oluştu. "Hazır" terminal sayıldığı için sonradan tamamlandı/iptal durumu izlenmiyor; geçmişte tüm durumlar detay açmıyor.

İşletmeye etkisi: Gereksiz timer ve müşteriye eski durum gösterme riski var. Durum panelden de değişebilir; Kerzz bağlantısı şart değil.

Yapıyı koruyan çözüm: Await sonrasında mounted kontrolü, tek uçuş polling ve dispose iptali ekle. Gerçek son durumlara kadar takip et; geçmişte tüm kayıtları okunabilir durum etiketiyle aç.

Kabul kontrolü: Dispose sonrası sıfır timer; yavaş ağda tek GET. ready -> cancelled/completed güncellemesi görünür, geçmiş detayı açılır.

Kanıt: Önceki kayıtlar: MOB-08, MOB-16

M/features/order/application/order_tracking_provider.dart:29 · M/features/order/application/order_tracking_provider.dart:74 · M/features/order/application/order_tracking_provider.dart:38 · M/features/order/domain/order_record.dart:28

Bakım ve hazırlık işleri

Önceki kayıt kimlikleri ve incelenen commit'e bağlı kod satırları her paketin altında. B/ backend, M/ mobil, A/ admin.

D22 | KALİTE / HAZIRLIK | İZOLE DERLEME KANITI

Derleme komutlarını birbiriyle eşleştir

TypeScript çıktı kökünde src/index.js oluşuyor; npm start ise dist/index.js bekliyor. Geliştirme sunucusu çalıştığı için bu uyumsuzluk görünmeyebilir.

İşletmeye etkisi: Çalışan local npm run dev akışını etkilemiyor; bu bir hosting eksikliği değildir. İleride standart build + start kullanıldığında ortaya çıkacak komut uyumsuzluğudur.

Yapıyı koruyan çözüm: Mevcut dizilimi koruyup start hedefini dist/src/index.js ile eşleştir veya ayrı build tsconfig kullan. Geliştirme tsx watch akışını koru.

Kabul kontrolü: Temiz geçici build'de start hedefi vardır; ayrı test ortamında başlatma ve health kontrolü geçer. Çalışan mevcut sunucu bu iş için durdurulmaz.

Kanıt: Önceki kayıtlar: BE-24
dosso-dossi-backend/package.json:8 · dosso-dossi-backend/tsconfig.json:7

D23 | PLANLI İYİLEŞTİR | ÖNCEKİ NPM AUDIT KAYDI

Bağımlılıkları kontrollü bakım planına al

02.10.2026 taramasında backend geliştirme dışı paket ağacında 7 etkilenen düğüm, tüm paketlerde 12 görüldü; adminde 0. Bunlar bağımsız 7/12 uygulanabilir saldırı kanıtı değildir.

İşletmeye etkisi: Bilinen duyurular bir bakım ihtiyacı oluşturur; gerçek risk çağrı yoluna bağlıdır. Bu turda tarama tekrarlanmadı, sürümler değişmedi.

Yapıyı koruyan çözüm: Önce kilit dosyası ve erişilebilir kod yollarını incele. Desteklenen yamaları ayrı dalda uygula; Prisma/ExcelJS için aracın önerdiği otomatik sürüm düşürmeyi yapma.

Kabul kontrolü: Her duyuru yama veya belgeli risk kararıyla kapanır; build, API ve CSV/XLSX testleri geçer. Mevcut uygulama kendiliğinden güncellenmez.

Kanıt: 02.10.2026 npm audit --omit=dev ve npm audit çıktıları; backend/package-lock.json. Paket zincirleri: Prisma/deepmerge-ts, ExcelJS/brace-expansion/uuid, Express/qs. [S4]

Bakım ve hazırlık işleri / devam

D24 | KALİTE / HAZIRLIK | STATİK RİSK / ÖLÇÜLMEDİ

Performansı ölç, sonra küçük adımlarla iyileştir

Revision isteği AuditLog üzerinde groupBy/count/max çalıştırıyor. Ön plandaki gerçek istemci, iş bittikten 3 sn sonra tekrar ediyor. Admin build'i yaklaşık 724 kB tek JS parçası uyarısı verdi.

İşletmeye etkisi: Bu yavaşlık kanıtı değil; büyümeden önce ölçülecek maliyet. 1.000 düşük gecikmeli açık istemcide trafik yaklaşık 333 istek/sn'ye yaklaşabilir.

Yapıyı koruyan çözüm: Staging'de sorgu planı ve p95 ölç. Gerekirse kısa revision cache'i/sayaç kullan; paneli sayfa bazlı böl. İlk çözüm olarak tüm sistemi WebSocket veya mikroservise taşıma.

Kabul kontrolü: Hedef yükte ölçüm kaydı, düşük DB maliyeti ve panel değişiminin beklenen sürede görünmesi. Cache eski veri bırakmaz.

Kanıt: B/features/sync/sync.service.ts:40; M/core/sync/revision_sync.dart:9,63; M/core/sync/app_data_sync.dart:22,72. Admin build çıktısı: 723,63 kB JS / 210,31 kB gzip.

Ekranların işleyişini güçlendir

Mevcut arayüzün tanıdık akışı korunur. Örnekler, düzeltmenin hangi kullanıcı anını iyileştireceğini gösteriyor.



Görseller: 30.09.2026 tarihli uygulama tanıtım demosu. Tutarlar örnek veridir; ekranlar güncel tasarımın birebir kanıtı veya bug tekrar üretimi değildir.

Ürün seçimi / D09

Aynı süt/shot farkı ekranda, sepette ve sunucuda. Fiyat değişirse ödeme öncesi açık onay.

QR süresi / D14

Sayaç sunucudaki gerçek son kullanma zamanını izler. Yenileme hatası eski kodu yeni gibi göstermez.

Yapıyı bozmadan uygulama yöntemi

Bu rapor uygulama kodunu değiştirmedir. Aşağıdaki sıra, ileride düzeltme yapılırken normal çalışan akışların korunması içindir.

Kural	Nasıl uygulanır?
Local düzen devam eder	Backend, veritabanı ve simülatör mevcut yerel düzende kalabilir. Hosting değişikliği bu işlerin ön koşulu değildir.
Her paket ayrı değişiklik	Örneğin önce yalnız çift iade servisi ve regresyon testi. Aynı değişikliğe yeni tasarım, framework yükseltme veya entegrasyon eklenmez.
Önce mevcut hatayı göster	Mevcut sonucu doğrulayan test yazılır; düzeltmeden sonra beklenen doğru sonuca çevrilir. Normal sipariş/iptal akışı da kontrol edilir.
Uyumlu API ve veri geçişi	Alan/indeks gerekiyorsa ekleyerek ilerlenir. Mevcut bakiye, damga ve siparişler sıfırlanmaz. Yeni kuralın eski kayıt davranışı açıkça tanımlanır.
Doğru ortamda doğrulama	Yarışlar ayrı test DB'sinde; görünüm simülatörde; rol sınırı doğrudan HTTP testinde denir. Kullanılan local veritabanında denetim siparişi oluşturulmaz.
Küçük teslim ve geri dönüş	Her paket sonunda fark ve test sonucu incelenir. Kod geri alınabilmeli; veri dönüşümü gerekiyorsa geri dönüş ayrıca planlanmalı.

Korunacak şeyler

Renk paleti ve ekran dili, navigasyon, repository/servis ayrımı, mevcut doğru ürün ve kampanya içerikleri. Yeniden yazım veya zorunlu altyapı taşıması önerilmiyor.

Finansal hatalarda eski yanlış kayıtları otomatik düzeltmek ayrı bir iştir. Önce etkilenen kayıtlar raporlanır; onaylanmış bir mutabakat olmadan bakiye veya haklara toplu müdahale edilmez.

Önerdiğim geliştirme sırası

Süre tahmini verilmedi: kapsamlılık, mevcut test altyapısı ve iş kuralı kararları süreyi değiştirir. Sıralama risk ve bağımlılığa göre.

1. Tur / Para ve hesap sınırı

D01-D08 + D13. Önce çift iade, ikram/damga yarışları ve negatif bakiye. Ardından tek işlem anahtarı, şube yetkisi, hesap değişimi, bloke hesap ve auth kuyruğu. Aktif siparişlerin panoda kaybolmasını da bu turda ele al.

2. Tur / Tek doğru kural ve fiyat

D09-D12 + D17. Panel ayarı, fiyat, şube ve ürün görseli aynı sözleşmeden beslensin. Hediye hakkının hangi ürünlerde geçerli olduğu kararı netleşsin. Mevcut kampanya hakları korunarak geçiş yapılsın.

3. Tur / Günlük kullanım ve raporlama

D14-D16 + D18-D21. QR hata/süre davranışı, yenileme ve boş/hata ekranları, erişilebilirlik, eksiksiz CSV/XLSX, doğru finans/KPI, OTP tek kullanım ve sipariş takibi.

Paralel, dar kapsam / Bakım

D22-D24. Start komutunun build çıktısıyla hizalanması, kontrollü bağımlılık yamaları ve ölçüm. Local geliştirme düzeni değişmeden yapılabilir; ölçmeden mimari dönüşüm yapılmaz.

Her turun çıkış koşulu: İlgili kabul kontrolleri geçer; mevcut başarılı regresyonlar korunur; normal sipariş, iptal, oturma ve panel düzenleme akışları yeniden denenir. "Derlendi" tek başına tamamlandı anlamına gelmez.

Bilgiler geldiğinde açılacak ayrı işler

Bu bölüm eksik saymak için değil, bekleyen işlerin bağımsız düzeltmelerle karışmasını önlemek için tutuldu.

Bekleyen iş	Açılma koşulu / gelecekteki kontrol
Gerçek ödeme / 3DS / kayıtlı kart	Sağlayıcının anahtar, test ortamı ve akış sözleşmesi gelince; pending/success/failure, webhook doğrulama ve aynı işlemin tekrar bildirilmesi denenir. Geliştirme ödeme davranışı şu an hata sayılmaz.
Kerzz gönderim ve iade sözleşmesi	Kerzz bilgileri gelince; kasadaki kabul/iptal ile cüzdan ve ikram ters kaydı eşleştirilir. Eski BE-05 bu kapsamda: gerçek POS iptali için olay anlamı netleşmeli.
POS yeniden gönderme	Gerçek işçi/iletim hattı hazır olunca; eski başarısız denemenin sonraki başarıyı ezmesi engellenir (BE-23). Panelde yeniden kuyruğa alma işlemi gerçek durumla uyumlu olur (ADM-11).
SMS / hediye teslim bildirimi	Sağlayıcı gelince; hediye kaydı ile teslim bildirimi ayrı takip edilir. Bildirim başarısız olsa bile oluşmuş hediye “yok” gibi gösterilmez (BE-14); güvenli yeniden gönderim denenir.
Canlı ortam geçişi	Kullanıcı canlıya geçmeye karar verdiğiğinde; hosting, TLS, güçlü production sırları, yedek/geri yükleme, izleme ve mağaza imzası ayrıca kontrol edilir. Local tercih için puan düşürülmedi.

Net sınır

D01-D21 için dış firmanın bilgisi gerekmiyor. Bu sayfadaki entegrasyon işleri ise kendi zamanında tamamlanır. İki listenin bitiş koşulları ayırdır; bu rapor gerçek banka/POS/SMS bağlantısının hazır olduğunu iddia etmez.

İlave iyileştirmeler ve karar noktaları

Aşağıdakiler 21 düzeltme paketinin dışında: ürün kararı, önleyici kontrol veya henüz tekrar üretilmemiş inceleme alanlarıdır.

Konu	Doğru değerlendirme / küçük adım
Gizlilik ve hesap silme	Mobilde gizlilik metni/hesap kapatma akışı ürün kararıyla tamamlanmalı (MOB-17). Gerçek veri silme, saklama ve finansal kayıt ilişkisi ayrıca tasarlanır. Banka bilgisi gerektirmez; bu rapor hukuki uygunluk onayı vermez.
Gerçek konuma göre mağaza	Mesafe hesabı sabit referansa dayanıyor (MOB-18). GPS bir özellik kararıdır. Konum alınmıyorsa "sana uzaklığı" izlenimi veren metin gizlenebilir veya referans açıklanabilir.
Salt okunur panel deneyimi	Server yazmayı reddediyor; ancak bazı yazma düğmeleri görünüyor (N03). Yetki olmayan düğmeleri açıklamalı kapatmak günlük kullanım kalitesini artırır.
Tarayıcı oturum saklama	Token'ın localStorage'da bulunması, olası XSS etkisini büyütür (N04); denetimde gerçek XSS kanıtı yok. Canlı web oturum/CSP stratejisi daha sonra ayrı ele alınır.
Nadir eşzamanlı admin durumları	Son süper admin ve çok sekmeli token yenileme için ek yarış testleri önerilir (N05/N06). Bu senaryolar bu çalışmada doğrulanmış olay gibi sunulmuyor.
Dokümantasyon ve yerel kurulum	README/test/çalıştırma notları gerçek local komutlarla hizalanmalı (OPS-04). Production sırlarının güç kontrolü (BE-21) canlı profil hazırlığıdır; mevcut sırlar zayıf diye bir ölçüm yapılmadı.

Mağaza politikası notu: Apple, hesap oluşturmayı destekleyen uygulamalarda uygulama içinden hesap silme başlatılabilmesini ister [S5]. Bu bir ürün/yayın kontrolüdür; teknik denetimden hukuki sonuç çıkarılmamalıdır.

İş paketleri dizini

Önce düzelt: para, erişim veya günlük işin doğruluğu. Planlı iyileştir: güvenilirlik ve kullanım. Bakım: ikincil hazırlık ve ölçüm.

Kod	İş paketi	Öncelik	S.
D01	Aynı siparişe yalnız bir kez iade	ÖNCE DÜZELT	6
D02	Bakiye düzeltmesi ve kuruş hassasiyeti	ÖNCE DÜZELT	6
D03	İkram ve damga hesabını yarışlara kapat	ÖNCE DÜZELT	7
D04	Tek kullanıcı niyeti, tek işlem	ÖNCE DÜZELT	7
D05	Şube müdürünün veri sınırını tamamla	ÖNCE DÜZELT	8
D06	Hesap değişiminde veri ve sepeti ayır	ÖNCE DÜZELT	8
D07	Bloklama ve oturum kapatma gerçekten etkili olsun	ÖNCE DÜZELT	9
D08	Oturum yenileme hatasında ekran takılmasın	ÖNCE DÜZELT	9
D09	Müşterinin onayladığı fiyatı koru	ÖNCE DÜZELT	10
D10	Panel ayarı, afiş ve gerçek kural aynı olsun	ÖNCE DÜZELT	10
D11	Şube seçimi ve özel fiyatı koru	PLANLI İYİLEŞTİR	11
D12	Kahve hediyesinin ürün kuralını netleştir	PLANLI İYİLEŞTİR	11

D01-D21 bağımsız düzeltme paketleridir. D22-D24 bakım/hazırlık başlığındadır. Her sayfadaki “Kanit” satırları önceki denetim kimliklerini ve incelenen commit’e ait kod bağlantılarını içerir.

İş paketleri dizini / devam

Önce düzelt: para, erişim veya günlük işin doğruluğu. Planlı iyileştir: güvenilirlik ve kullanım. Bakım: ikincil hazırlık ve ölçüm.

Kod	İş paketi	Öncelik	S.
D13	Aktif sipariş panosunda iş kaybolmasın	ÖNCE DÜZELT	12
D14	QR ekranı kendi süresine güvenilir davransın	PLANLI İYİLEŞTİR	12
D15	Yenileme, boş veri ve tercih hatalarını görünür yap	PLANLI İYİLEŞTİR	13
D16	Küçük ekran ve erişilebilirliği tamamla	PLANLI İYİLEŞTİR	13
D17	Yeni ürün fotoğrafı her yerde aynı görünsün	PLANLI İYİLEŞTİR	14
D18	Finans dışı aktarımı eksiksiz ve güvenli olsun	PLANLI İYİLEŞTİR	14
D19	Müdür raporlarını gerçek kayıtlarla eşleştir	PLANLI İYİLEŞTİR	15
D20	OTP tüketimi ve deneme sınırlarını güçlendir	PLANLI İYİLEŞTİR	15
D21	Takip ekranının yaşam döngüsünü düzelt	PLANLI İYİLEŞTİR	16
D22	Derleme komutlarını birbiriyle eşleştir	KALİTE / HAZIRLIK	17
D23	Bağımlılıkları kontrollü bakım planına al	PLANLI İYİLEŞTİR	17
D24	Performansı ölç, sonra küçük adımlarla iyileştir	KALİTE / HAZIRLIK	18

D01-D21 bağımsız düzeltme paketleridir. D22-D24 bakım/hazırlık başlığındadır. Her sayfadaki “Kanit” satırları önceki denetim kimliklerini ve incelenen commit’e ait kod bağlantılarını içerir.

Kaynaklar ve son değerlendirme

İç kanıtlar belirli bir commit'e, dış kaynaklar kontrol prensiplerine bağlandı. Kaynaklar 02.10.2026 değerlendirmesine aittir.

Kaynak	Ne için kullanıldı?
[K1] Kaynak kod	berkay-branch / d3cfc34cd869b83093bb60de21a83e07aae5cc55. Bulgu altındaki tıklanabilir bağlantılar bu sabit sürüme gider. B/: backend/src, M/: app/lib, A/: admin/src.
[K2] Önceki denetim	02.10.2026 tarihli ilk production hazırlık denetiminin backend/admin/mobile JSON kayıtları, izole test gözlemleri ve analiz/build çıktıları. Bu raporda yeniden çalıştırılmadı.
[S1] İş kuralı güvenliği	OWASP Business Logic Security Cheat Sheet . Tek işlem, durum geçişi ve yarış kontrollerine arka plan.
[S2] Yetkilendirme	OWASP Authorization Cheat Sheet . Yetkiyi her istekte uygulama, asgari erişim ve rol regresyonları.
[S3] CSV güvenliği	OWASP CSV Injection . Kullanıcı metninin hesap tablosunda formüle dönüşmesi. Tek kaçış yöntemi her uygulamada evrensel çözüm değildir; hedef uygulamada test gerekir.
[S4] Bağımlılık taraması	Önceki npm audit JSON çıktıları: backend prod 7, tüm bağımlılıklar 12; admin 0. Bunlar araç sınıflarıdır, 12 erişilebilir saldırı kanıtı değildir. Bu tur tekrar taranmadı.
[S5] Hesap silme	Apple: Offering account deletion in your app . Hesap oluşturan uygulamanın silme başlatma deneyimine ilişkin mağaza kuralı.

Benim önerim

Mevcut projeye devam et. Local çalışma düzenini koruyarak önce para/ikram tutarlılığını ve hesap sınırlarını, sonra fiyat/ayar sözleşmesini sağlamlaştı. Bekleyen entegrasyonları bug gibi değerlendirmeden, mevcut koddaki kanıtlı sorunları küçük ve testli değişikliklerle kapat.

Bu belge bağımsız yapının güçlendirme planıdır; canlıya çıkış sertifikası veya penetrasyon testi değildir. Uygulama, backend, admin, yapılandırma ve mevcut veritabanında değişiklik yapılmadı.